

Identity & Access Management Audit

Executive Summary

Organisation: NovaTech Solutions (Fictional)
Assessment Type: Simulated Internal IAM Security Audit
Frameworks Aligned : NIST CSF 2.0 and ISO/IEC 27001:2022

Assessment Overview

A simulated internal audit was conducted to assess the design and operating effectiveness of key Identity and Access Management (IAM) controls within NovaTech Solutions.

The assessment reviewed authentication, user and contractor access lifecycle management, privileged access, service accounts, access reviews, access approvals, and administrative activity logging.

Assessment Result

Result	Total
Evidence Areas Reviewed	12
Audit Findings	5
High-Risk Findings	4
Medium-Risk Findings	1
Critical / Low Findings	0

Key Findings

HIGH - Incomplete MFA Enforcement

15 of 186 active accounts were capable of remote authentication without MFA.

HIGH - Inadequate User & Contractor Offboarding

Access was not consistently removed following employee departures and contractor engagement completion.

MEDIUM - Inadequate Periodic Access Reviews

A quarterly access review was missed, and Finance application access was not included in the previous review.

HIGH - Shared Privileged Account Governance

A shared Global Administrator account reduced individual accountability and lacked documented governance over emergency use.

HIGH - Service Account Governance

Six service accounts lacked documented owners, including three accounts with privileged permissions.

Framework Alignment

The identified findings were mapped to relevant outcomes within the NIST Cybersecurity Framework (CSF) 2.0, primarily under PR.AA – Identity Management, Authentication, and Access Control.

Findings were also mapped to relevant ISO/IEC 27001:2022 Annex A controls across A.5 – Organisational Controls and A.8 – Technological Controls, including controls relating to identity management, access rights, privileged access, and secure authentication.

Detailed control mappings and rationale are documented separately in the project's Framework Mapping.

Conclusion

The assessment identified weaknesses primarily relating to authentication enforcement, access lifecycle management, privileged access governance, and periodic access review.

Controls relating to new-user provisioning, privileged-access approval, and administrative activity logging operated effectively within the samples reviewed.

Priority should be given to enforcing MFA, strengthening user and contractor offboarding, and improving governance over privileged and service accounts.